

ANSWER SHAPE — THE DOCTOR'S FORMAT, LEARN THIS FIRST

The quiz is **written / essay, about 10 minutes**, at the start of the lecture. Soft stakes — a reading check.

- **Numbers given** → apply the formula.
- **No numbers** (analytical scenario) → **step** → **name the CIA pillar** → **(techniques in brackets)**.

Week 01 — the six equations

#	Equation	Meaning and symbols
1	$\min R = \sum P_i I_i - \sum C_j$	Cybersecurity as an optimisation problem . Minimise residual risk = expected loss ($\sum$ probability $\times$ impact) minus the cost of controls. Spend on a control only while it removes more loss than it costs.
2	$R(t) = \sum P_i(t) I_i(t)$	Expected risk at time t , summed over all threats. Awareness only — the doctor said you just need to know the law exists.
3	$U(C, I, A) = \alpha C + \beta I + \gamma A$	Security utility function . C, I, A normalised 0–1; α, β, γ are the importance weights for that system. Weights are not fixed — see the domain table below.
4	$AS = \sum (E_j \cdot V_j \cdot A_j)$	Attack surface . E_j exposed entry points · V_j vulnerability severity (CVSS score) · A_j asset value. A product , not a sum — all three must matter.
5	$P(R > r) = 1 - F(r)$	Probability that risk exceeds a threshold r . F is a CDF , so its range is always [0, 1] ; $1 - F(r)$ gives the tail probability.
6	$PCI = \sum w_k c_k / \sum w_k$	Policy compliance index — a weighted average . c_k compliance level for requirement k (0–1); w_k its importance weight. Result 0–1 ($\times 100$ for a percentage).

Week 01 — the CIA triad (the doctor's red-highlighted core)

WHY THIS IS THE MOST IMPORTANT TABLE

These technique names are the words you write **inside the brackets** of every scenario answer. Without them the answer is incomplete.

Pillar	Definition	Techniques — write these in the brackets
Confidentiality	Preventing unauthorised access to data	encryption access controls VPNs
Integrity	Ensuring data is accurate and unmodified	hashing (SHA-256) digital signatures version control
Availability	Ensuring resources are available when needed	redundancy load balancing DDoS mitigation

The weights change with the domain — a likely essay question

Domain	Heaviest pillar	Why
Healthcare	Confidentiality (α)	Patient records — privacy above all. The doctor wrote this in red: confidentiality has higher weight than availability.
Banking	Integrity (β)	If a figure in an account changes, it is a disaster
Emergency services	Availability (γ)	The system must work at all times

Chapter 5 — three terms that get confused

Term	Definition
Risk	A function of probability $\times$ impact
Vulnerability	A weakness — software, hardware or human (OWASP Top 10, CVEs)
Exploit	The tool or method that uses a vulnerability

Chapter 6 — evolution and frameworks

Era	Character
Early (1960s–1990s)	Perimeter defence — firewalls, antivirus
Modern (2000s–now)	Cloud, IoT, mobile, AI-powered attacks

Framework	Body · covers
GDPR	EU · data protection and privacy
HIPAA	USA · health-care information
NIST / ISO 27001	International · international standards

EXCLUDED — DO NOT REVISE IT

Chapter 7 is out of the exam: Stuxnet · Colonial Pipeline · GDPR enforcement. The doctor said she does not want it.

The two equations

Equation	Symbols
$S = F \times K$	S basic risk · F frequency of attempts to exploit the vulnerability · K consequences of a successful attempt
$R = S / M$	R residual risk · S risk of the threat · M level of countermeasures — number AND effectiveness

HOW TO USE THEM

The scale is **ordinal** (low / medium / high) and the book’s own examples print “**medium × high = medium**”. **Read the colour off the matrix — do not multiply the words as numbers.**

Matrix	Axes	Red corner
Risk matrix	frequency × consequences	high and high
Residual risk matrix	risk ÷ countermeasures	high risk, low countermeasures

WHY MULTIPLY, NOT ADD

Multiplication collapses when **either** factor is near zero — a constant nuisance that harms nothing is not a catastrophe. Addition would let a huge frequency compensate for **zero** consequence, which is nonsense. **Both factors must matter.**

The five lists, in order

List	Items
Mitigation strategies	1 avoidance · 2 reduction · 3 retention · 4 transfer · 5 sharing
Dealing with damage	1 preventing · 2 complicating · 3 diverting (1–3 proactive) · 4 detecting · 5 reestablishing (4–5 reactive)
OCTAVE phases	1 asset-based threat profiles · 2 infrastructure vulnerabilities · 3 security strategy and plans
PDCA	plan (identify, analyse, plan) · do (implement) · check (monitor) · act (adjust or start a new plan)
Cyber risk assessment	1 identification · 2 evaluation · 3 mitigation · 4 monitoring and review

Frameworks — one line each

COBIT	Objectives for measures to manage risk
COSO	Internal processes inside the company
FAIR	The only one with a calculation model ; also a naming standard
ISO/IEC 27002	A checklist . 27001 = requirements (audited against); 27002 = code of practice
OCTAVE	A process ; Carnegie Mellon, for the US DoD

The numbers to remember

#	What
2	Equations
4	Threat groups — hardware · software · data · liveware
5	Risk mitigation strategies — avoidance · reduction · retention · transfer · sharing
5	Analysis frameworks — COBIT · COSO · FAIR · ISO/IEC 27002 · OCTAVE
5	Dealing with damage — preventing · complicating · diverting · detecting · reestablishing
14	ISO/IEC 27002 categories (2013 structure)
3	OCTAVE phases
4	OCTAVE variants in the book (3 exist publicly)
4	PDCA — plan · do · check · act
4	Authentication factors — knowledge · possession · inheritance/inherence · location
4	Cyber risk assessment — identification · evaluation · mitigation · monitoring

Traps, in order

- A threat is not a vulnerability.** Weakness alone = vulnerability; actor alone = threat.
- Multiplication, not addition** (AS and S = F × K).
- Red has exactly one cell** in each matrix.
- Do not mix the matrices.**
- M is number AND effectiveness** — not just a count.
- The two five-item lists differ** — dealing with damage vs mitigation strategies.
- Proactive 1–2–3, reactive 4–5.**
- Act restarts PDCA** — a cycle, not a line.
- OCTAVE phases 3, variants 4.**
- Authentication factors = 4** — most people forget **Location**.
- Authorisation is based on authentication.**
- Insider threats → administrative controls** (vetting, training), not technology.
- Three remote terms differ by word order** — monitoring · remote-access control · remote-control access.

WRITE HER ANSWER — AND KNOW THE CORRECT FACT

She marks	Correct fact
14 ISO/IEC 27002 categories	14 is the 2013 structure (114 controls in 14 clauses); 2022 is 4 themes / 93 controls
4 OCTAVE variants	Public OCTAVE documents only 3 — OCTAVE, -S, Allegro
Inheritance	The correct term is inherence (something you are)

Answer in her vocabulary — she marks it. Add the correction in brackets only if there is room; it shows mastery rather than contradicting her.

THREE SENTENCES WORTH MEMORISING WORD FOR WORD

- “**Authorisation is based on authentication.**”
- “The **door** provides the physical barrier but in itself will only keep honest people out. The **lock** provides the authentication function.”
- “**If security measures do not give a usable system, users will find ways to avoid them!**”